

TALATBEK URUNOV

Independent Security Researcher · Vulnerability Discovery

Email talatbekurinov303@gmail.com GitHub github.com/TalatbekUrunov
LinkedIn linkedin.com/in/talatbek-urunov- Portfolio talatbekurunov.github.io

PROFILE

HTB-certified security researcher specialising in **open-source vulnerability discovery**. Independently found **8 novel vulnerabilities** across widely-used npm packages — spanning arbitrary code execution, unsafe deserialization, and algorithmic denial of service — each verified with a working proof-of-concept, cross-checked for novelty, reported through coordinated disclosure, and shipped with a proposed fix.

8 NOVEL FINDINGS	1 CRITICAL · 9.8	1 HIGH · 8.1	~98M MONTHLY DOWNLOADS	5 VULN CLASSES
---------------------	---------------------	-----------------	------------------------------	-------------------

VULNERABILITY RESEARCH

PACKAGE	CLASS	SEVERITY	IMPACT	DOWNLOADS
gray-matter	CWE-94 · Code Injection	CRIT 9.8	RCE via ---js eval engine	~30M/mo
yaml-front-matter	CWE-502 · Deserialization	HIGH 8.1	Code exec via !!js/function	~353K/mo
strip-comments	CWE-1333 · ReDoS	MED 5.3	O(2 ⁿ) exponential · ~39 s	~36M/mo
platform	CWE-1333 · ReDoS	MED 5.3	O(n ²) quadratic · UA · ~22 s	~25M/mo
semver-utils	CWE-1333 · ReDoS	MED 5.3	O(n ³) cubic · ~19 s	~2M/mo
underscore.string	CWE-1333 · ReDoS	MED 5.3	O(n ²) quadratic · stripTags	~4M/mo
auth-header	CWE-1333 · ReDoS	MED 5.3	O(n ²) quadratic · ~26 s	~530K/mo
configparser	CWE-1333 · ReDoS	MED 5.3	O(n ³) polynomial · ~88 s	~132K/mo

CERTIFICATIONS

Certified Penetration Testing Specialist (CPTS)

Hack The Box · Jul 2026
HTBCERT-8560F4D0B7

Certified Web Exploitation Specialist (CWES)

Hack The Box · Jun 2026
HTBCERT-7FDA841FCA

SELECTED HIGHLIGHTS

- ▶ **Critical RCE** in gray-matter (~30M downloads/mo) — arbitrary JS from user-submitted markdown.
- ▶ First to report an **exponential-time** ReDoS in strip-comments; distinct stripTags ReDoS separate from CVE-2017-16116.
- ▶ All findings **novelty-verified** against OSV.dev & GitHub Advisory DB before disclosure.

SKILLS & TOOLKIT

DISCOVERY & ANALYSIS

- recheck
- Static regex extraction
- AST source auditing
- Sink tracing · eval / Function
- Event-loop profiling

VERIFICATION & DISCLOSURE

- End-to-end PoC harness
- OSV.dev
- GitHub Advisory DB
- MITRE CVE request
- CVSS 3.1
- Coordinated disclosure

OFFENSIVE SECURITY

- Web exploitation
- Penetration testing
- Burp Suite
- Active Directory
- JavaScript / Node.js internals

CVE identifiers pending assignment (MITRE). Research conducted against own environments; PoCs benign. Generated from talatbekurunov.github.io